

QuoteCraft Architecture Review

Executive Summary

- QuoteCraft is a Silver-tier internal microservice handling Restricted data (PII + financial), deployed on AlphaPaaS AWS with Azure-managed Postgres and AWS-managed Redis/EFS.
- Multiple critical security and availability gaps exist: secrets handling, network exposure, encryption, and multi-AZ resilience.
- Non-production cost overruns and provisioned storage waste breach FinOps standards.
- Scalability is constrained by in-memory rate limiting and single-replica deployment, risking both performance and resilience.
- Remediation actions are clear and actionable, with several tracked in backlog tickets but not yet scheduled.

Findings

Cost

F-01: Non-production environment cost overrun

- Severity: Critical
- Dimension: Cost
- Evidence:
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "The FinOps team flagged in March 2026 that QuoteCraft's non-production environment is consuming approximately 35% of what production consumes. The cause has not been investigated."
- Policy reference: FIN-07
- Why it matters: Exceeding the 20% threshold triggers a FinOps review and risks budget ineligibility.
- Remediation: Investigate non-prod resource sizing and scheduling; reduce spend to $\leq 20\%$ of production; document exceptions if needed.
- Confidence: High

F-02: Provisioned throughput EFS waste

- Severity: High
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/efs.tf
- Quote: "Provisioned throughput. Originally set during the pilot when we thought PDF generation would be I/O bound. It isn't. Tracked in QC-211."
- Policy reference: FIN-06
- Why it matters: Unnecessary provisioned throughput increases monthly storage costs.
- Remediation: Switch EFS to standard throughput mode unless documented IOPS requirement exists.
- Confidence: High

F-03: No S3 lifecycle policy for quote archives

- Severity: Medium
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/s3.tf
- Quote: "# NB: No lifecycle configuration. Quote archives are kept in STANDARD storage class indefinitely. There was a ticket to add glacier transition (QC-134) but it was deprioritised."
- Policy reference: FIN-13
- Why it matters: Keeping archives in standard storage increases long-term costs.
- Remediation: Implement S3 lifecycle policy to transition archives to Glacier after retention period.
- Confidence: High

F-04: Application logs retention exceeds Silver tier

- Severity: Low
- Dimension: Cost
- Evidence:
- Source: app:infra/aws/cloudwatch.tf
- Quote: "retention_in_days = 365" (for application logs)
- Policy reference: FIN-16
- Why it matters: Silver tier requires 90-day retention for application logs; longer retention increases storage costs.
- Remediation: Reduce application log retention to 90 days unless regulatory/business justification exists.
- Confidence: High

Security

F-05: Secrets exposed as environment variables

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "envFrom: ... secretRef: ... name: quotecraft-secrets"

- Source: app:deploy/openshift/secret-aws-keys.yaml
- Quote: "AWS_ACCESS_KEY_ID ... AWS_SECRET_ACCESS_KEY ... valueFrom: secretKeyRef"
- Policy reference: CKS-11, DCH-07
- Why it matters: Secrets in environment variables risk disclosure via logs, dumps, and process listings.
- Remediation: Refactor deployment to mount secrets as file volumes; remove envFrom and secretKeyRef for secrets.
- Confidence: High

F-06: Use of long-lived IAM user access keys

- Severity: Critical
- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/secret-aws-keys.yaml
- Quote: "# Long-lived IAM user access keys for reading from AWS Secrets Manager and mounting EFS. Created by the initial platform onboarding. There's a ticket to migrate to IRSA (QC-203) but it's not scheduled yet."
- Policy reference: AHS-11, ASC-06
- Why it matters: Long-lived credentials are prohibited; workload identity federation is required.
- Remediation: Migrate to IRSA (IAM Roles for Service Accounts) for AWS access; rotate and remove IAM user keys.
- Confidence: High

F-07: Public network access enabled for Azure Postgres

- Severity: High
- Dimension: Security
- Evidence:
- Source: app:infra/azure/postgres.tf
- Quote: "public_network_access_enabled = true"
- Policy reference: ASC-03, AHS-15
- Why it matters: Public access exposes the database to internet traffic, breaching private connectivity requirements.
- Remediation: Disable public network access; ensure all traffic routes via Private Endpoint and vWAN

Hub.

- Confidence: High

F-08: TLS certificate verification disabled for external API

- Severity: High

- Dimension: Security

- Evidence:

- Source: app:src/quotecraft/integrations/bureau.py

- Quote: "verify=False ... TODO(QC-189): migrate to verify=True once the Atlas production CA is added to the base image trust store."

- Policy reference: DCH-05

- Why it matters: Disabling certificate verification risks MITM attacks and data compromise.

- Remediation: Add Atlas CA to trust store; enable verify=True for bureau API calls.

- Confidence: High

F-09: Redis transit encryption disabled

- Severity: High

- Dimension: Security

- Evidence:

- Source: app:infra/aws/elasticache.tf

- Quote: "transit_encryption_enabled = false"

- Source: app:src/quotecraft/cache.py

- Quote: "# NB: redis:// (not rediss://). ElastiCache was provisioned without transit_encryption_enabled to simplify the initial migration from the in-process cache."

- Policy reference: ASC-05, DCH-04

- Why it matters: Unencrypted Redis traffic exposes Restricted data (PII) to interception.

- Remediation: Enable transit encryption for ElastiCache; update application to use rediss:// and CA bundle.

- Confidence: High

F-10: Role with wildcard permissions in RBAC

- Severity: Medium

- Dimension: Security
- Evidence:
- Source: app:deploy/openshift/rbac.yaml
- Quote: "apiGroups: [\"*\"] resources: [\"*\"] verbs: [\"*\"]"
- Policy reference: CKS-14
- Why it matters: Wildcard permissions risk privilege escalation and unauthorized access.
- Remediation: Restrict Role permissions to only required resources and verbs.
- Confidence: High

F-11: Application logs may contain full quote payloads including PII

- Severity: Medium
- Dimension: Security
- Evidence:
- Source: app:src/quotecraft/api/quotes.py
- Quote: "Log the full payload so Support can reproduce the failure. (Flagged in the Feb 2026 security spot-check; QC-188 will redact.)"
- Policy reference: DCH-06, DCH-11
- Why it matters: Logging PII breaches data handling standards and risks regulatory non-compliance.
- Remediation: Implement payload redaction in error logging; ensure no PII is logged.
- Confidence: High

Scalability

F-12: In-memory rate limiter not safe for horizontal scaling

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:src/quotecraft/middleware/rate_limit.py
- Quote: "Module-level singleton; NOT shared across pods. ... horizontal scaling will be addressed in QC-201."
- Source: app:docs/runbook.md
- Quote: "This is a known issue with the current in-memory rate limiter when the service is scaled to

multiple pods — each pod enforces the limit independently."

- Policy reference: ARS-14
- Why it matters: Rate limits are enforced per pod, not globally, risking quota breaches and inconsistent throttling.
- Remediation: Move rate limiter state to Redis or another external store to support multi-replica scaling.
- Confidence: High

F-13: Single-replica deployment in production manifest

- Severity: High
- Dimension: Scalability
- Evidence:
- Source: app:deploy/openshift/deployment.yaml
- Quote: "replicas: 1"
- Policy reference: ARS-13
- Why it matters: Single replica cannot absorb traffic spikes or failures; Silver tier requires minimum 3 replicas.
- Remediation: Update deployment to minimum 3 replicas; configure HPA for dynamic scaling.
- Confidence: High

F-14: Database connection pool not implemented

- Severity: Medium
- Dimension: Scalability
- Evidence:
- Source: app:src/quotecraft/db.py
- Quote: "# TODO(QC-142): migrate to psycopg_pool.ConnectionPool once we address the connection storm issue reported in INC-44231."
- Policy reference: ARS-06
- Why it matters: Opening a new connection per request risks exhaustion and performance bottlenecks at peak load.
- Remediation: Implement connection pooling for Postgres.
- Confidence: High

Availability

F-15: Single-AZ Redis and Postgres deployments

- Severity: Critical
- Dimension: Availability
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "High availability: single-zone (see 'Open items' below)" (Postgres); "Nodes: 1 (single-AZ)" (Redis)
- Source: app:infra/aws/elasticache.tf
- Quote: "num_cache_nodes = 1 ... availability_zone = \"\${var.aws_region}a\""
- Source: app:infra/azure/postgres.tf
- Quote: "# Zone-redundant HA is not configured."
- Policy reference: ARS-18, ASC-03
- Why it matters: Loss of a single AZ would cause service outage and data loss, breaching Silver tier requirements.
- Remediation: Enable zone-redundant HA for Postgres; deploy Redis as a multi-AZ replication group.
- Confidence: High

F-16: No documented DR exercise performed

- Severity: High
- Dimension: Availability
- Evidence:
- Source: app:docs/capacity-plan.md
- Quote: "DR exercise: **not yet performed.** Scheduled for Q3 2026."
- Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
- Quote: "DR testing Not yet performed. Scheduled for Q3 2026."
- Policy reference: ARS-20
- Why it matters: Without DR testing, recovery procedures are unverified and risk extended outages.
- Remediation: Schedule and execute DR exercise simulating AZ loss; document outcome and remediation plan.
- Confidence: High

F-17: Route exposure label mismatch and insecure termination policy

- Severity: High
- Dimension: Availability
- Evidence:
 - Source: app:deploy/openshift/route.yaml
 - Quote: "router: external ... insecureEdgeTerminationPolicy: Allow"
 - Source: case:hackathon-assets/hackathon-quotecraft-intake-form.pdf
 - Quote: "Exposure Internal only — intended router label: router=irp"
 - Policy reference: AHS-05, AHS-07
- Why it matters: Route is labelled external but intended as internal; insecure termination policy allows plaintext downgrades.
- Remediation: Correct router label to 'irp'; set insecureEdgeTerminationPolicy to 'Redirect'.
- Confidence: High

F-18: Use of deprecated DeploymentConfig resource

- Severity: Medium
- Dimension: Availability
- Evidence:
 - Source: app:deploy/openshift/worker-deploymentconfig.yaml
 - Quote: "kind: DeploymentConfig"
 - Policy reference: ARS-03, ARS-23
- Why it matters: DeploymentConfig is deprecated; Silver tier workloads must use Deployment.
- Remediation: Migrate worker deployment to apps/v1 Deployment resource.
- Confidence: High

Highest Priority Next Actions

1. Refactor secrets handling to mount as file volumes, removing environment variable exposure (CKS-11, DCH-07).
2. Migrate AWS access to IRSA, rotate and remove long-lived IAM user keys (AHS-11, ASC-06).
3. Enable zone-redundant HA for Azure Postgres and multi-AZ Redis (ARS-18, ASC-03).

4. Investigate and reduce non-production environment cost to $\leq 20\%$ of production (FIN-07).
5. Correct Route exposure label and termination policy to match intended internal exposure (AHS-05, AHS-07).

Report Quality Check

- Findings are grouped by Cost, Security, Scalability, Availability. ****Pass****
- Every finding cites at least one evidence source. ****Pass****
- Every finding cites at least one policy clause. ****Pass****
- Findings are specific to QuoteCraft, not generic cloud advice. ****Pass****
- Recommendations are concrete enough for backlog tickets. ****Pass****